GRC102 Security Governance Simulation

Practical Lab 8: Monitoring, Auditing Controls and Executive Reporting

Student: Zainab Umar Shuaibu

Student ID: C11/26/CGRCE/17194

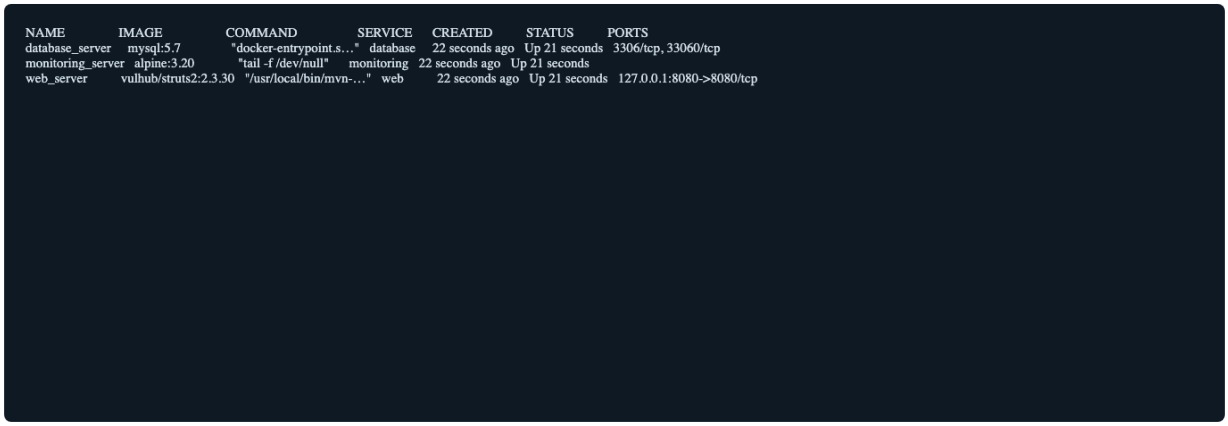
Generated: 11 October 2026 at 10:13 AM WAT

Environment: Isolated local Docker environment

Part 1 — Setting Up a Simulated Environment

The baseline combines an intentionally vulnerable Struts training service, a database containing three explicitly synthetic rows, and a monitoring container on one shared network. Loopback-only port binding prevents external exposure. This models delayed patching, weak authentication, and insufficient segmentation while limiting the activity to the authorised host.

Baseline Docker environment



Actual docker compose ps output from the isolated lab.

Figure 1: Baseline Docker environment. The container listing demonstrates that the web, database, and monitoring services ran inside the authorised local Docker lab.

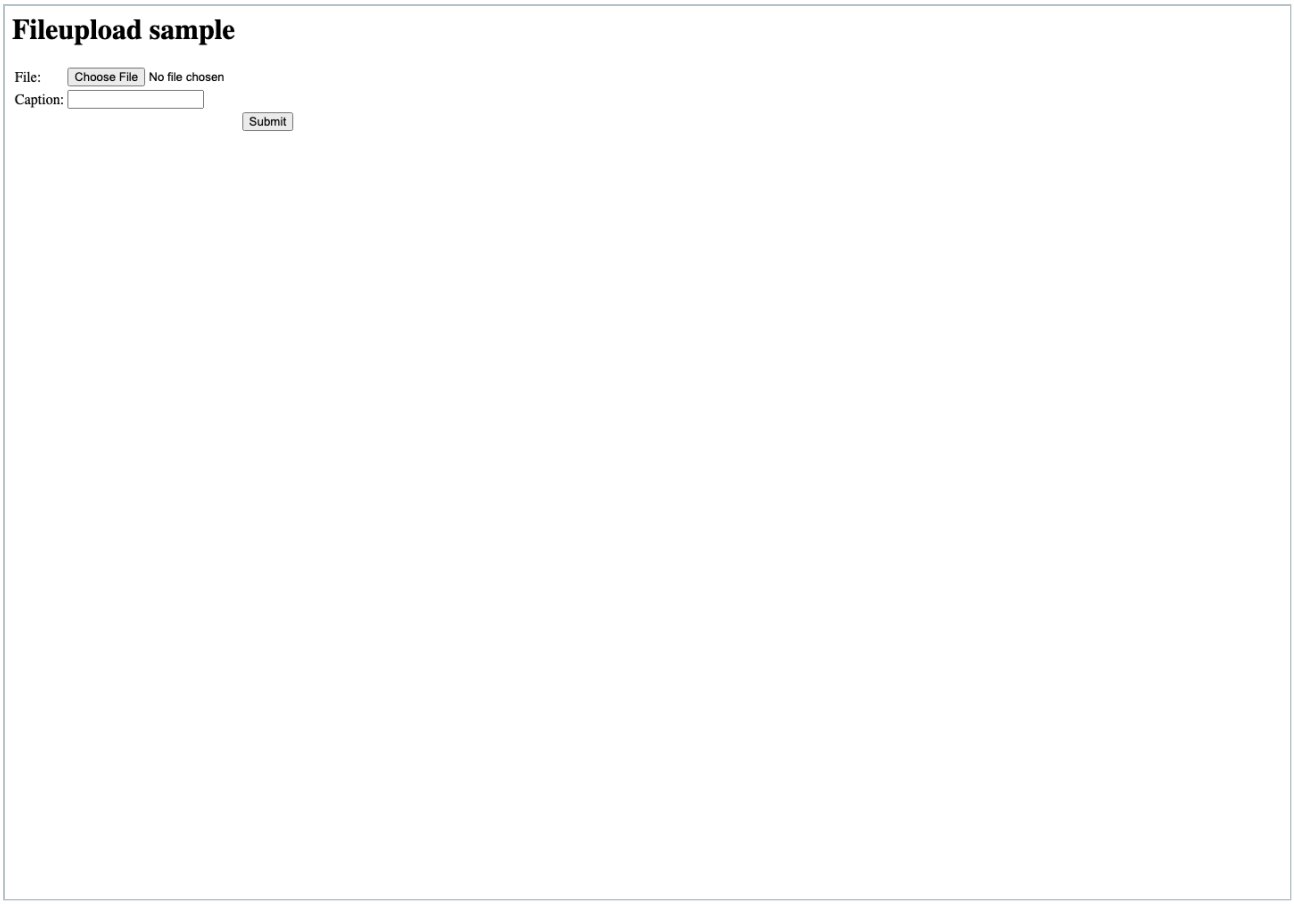


Figure 2: Customer-facing baseline application. The intentionally vulnerable training application was reachable only through the loopback interface.

Baseline vulnerability scan


```
{
 "scan_date": "2026-10-11T09:56:23+01:00",
 "mode": "baseline",
 "authorised_scope": "Local Docker lab only",
 "findings": [
  {
   "id": "CVE-2017-5638",
   "title": "Apache Struts S2-045",
   "severity": "Critical",
   "vulnerable": true,
   "evidence": "X-Vulnerable response header present"
  },
  {
   "id": "DB-AUTH-001",
   "title": "Default database credentials",
   "severity": "High",
   "vulnerable": true,
   "evidence": "5.7.44"
  },
  {
   "id": "NET-SEG-001",
   "title": "Insufficient network segmentation",
   "severity": "Medium",
   "vulnerable": true,
   "evidence": "Shared networks: grc102-security-governance-lab_secgov_baseline"
  }
 ],
 "summary": {
  "critical": 1,
  "high": 1,
  "medium": 1,
  "low": 0,
  "unknown": 0
 }
}
```


Timestamped scanner output generated from live container checks.

Figure 3: Baseline vulnerability scan. The scanner records the critical Struts exposure, default database authentication, and shared-network condition.

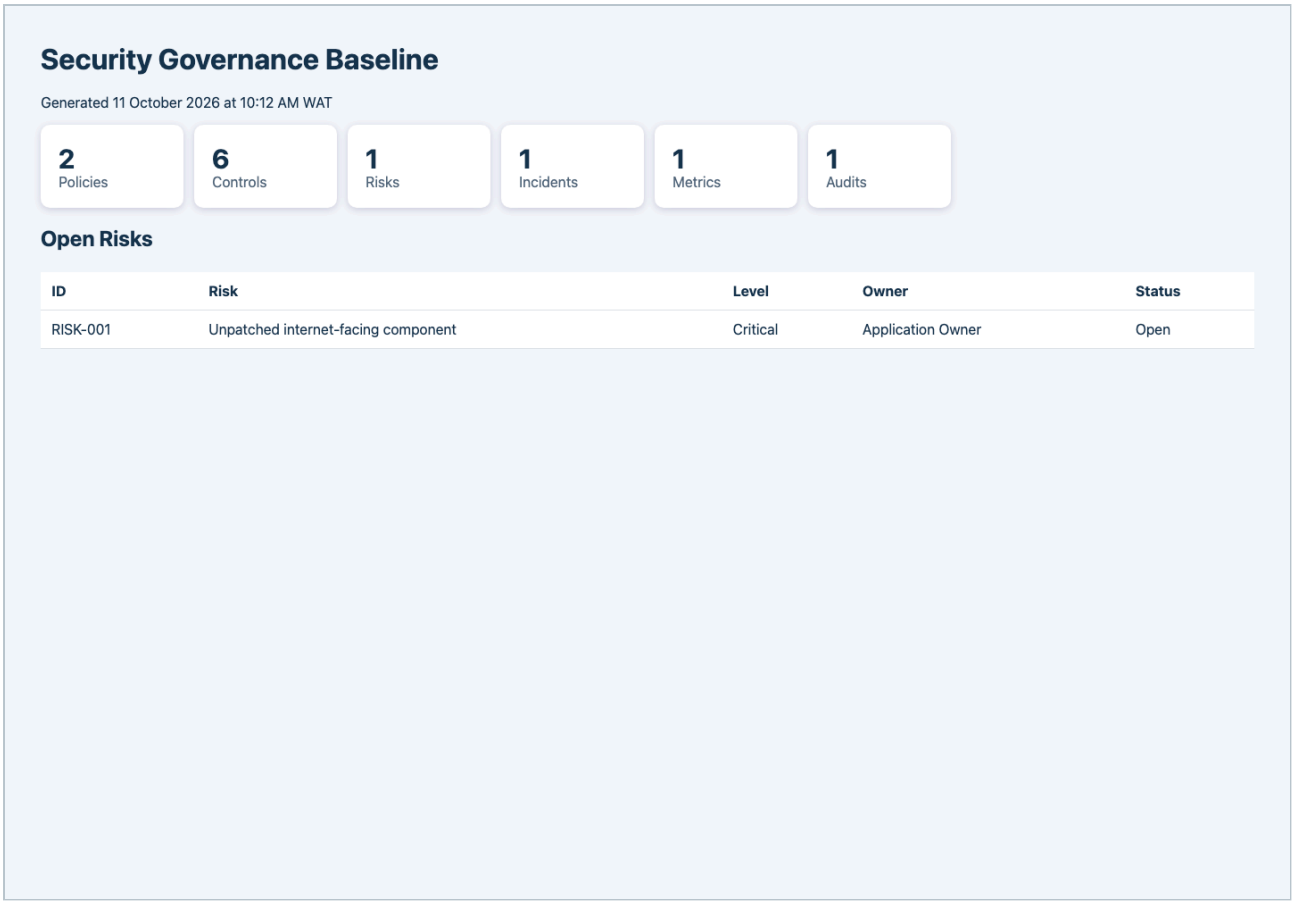


Figure 4: Governance tracker dashboard. The baseline register connects policies, controls, risks, incidents, metrics, audits, and accountable owners.

Part 2 — Analysing Security Governance Failures

The safe request confirmed whether the S2-045 response behaviour was present; it did not execute operating-system commands or access the database. The analysis identified failures in remediation, access control, architecture, monitoring, policy enforcement, and executive accountability. These mirror governance lessons from Equifax while avoiding a claim that the small simulation reproduces the scale or impact of that incident.

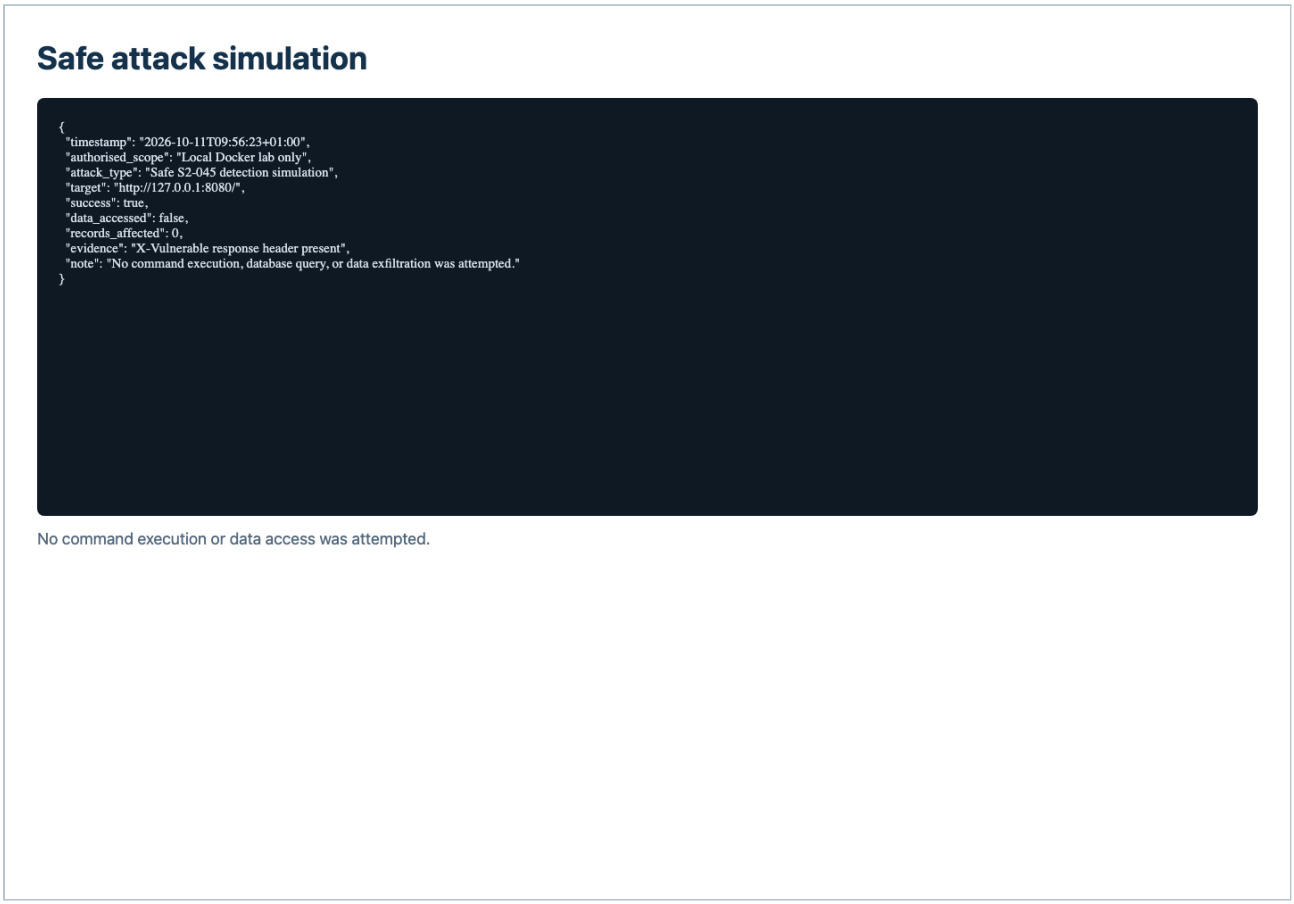


Figure 5: Safe attack simulation. The simulation performs detection only and explicitly records that no data was accessed or exfiltrated.

Governance failure analysis


```
{
 "generated_at": "2026-10-11T09:56:23+01:00",
 "source": "evidence/baseline/vulnerability_report_20261011_095623.json",
 "total_failures": 6,
 "failures": [
  {
   "category": "Patch and Vulnerability Management",
   "finding_id": "CVE-2017-5638",
   "failure": "Apache Struts S2-045",
   "impact": "Known critical weakness remained exposed",
   "accountable_owner": "Application Owner",
   "recommendation": "Replace the component and enforce a seven-day critical patch SLA"
  },
  {
   "category": "Authentication and Access Control",
   "finding_id": "DB-AUTH-001",
   "failure": "Default database credentials",
   "impact": "Default database credentials permit unauthorised access",
   "accountable_owner": "Database Owner",
   "recommendation": "Use unique secrets and least-privilege accounts"
  },
  {
   "category": "Security Architecture",
   "finding_id": "NET-SEG-001",
   "failure": "Insufficient network segmentation",
   "impact": "A shared network enables lateral movement",
   "accountable_owner": "Network Owner",
   "recommendation": "Separate frontend and data networks"
  },
  {
   "category": "Monitoring and Detection",
   "finding_id": "GOV-MON-001",
   "failure": "No effective baseline alerting",
   "impact": "Malicious activity may remain undetected",
   "accountable_owner": "Security Operations",
   "recommendation": "Monitor critical services and escalate alerts"
  },
  {
   "category": "Policy Enforcement",
   "finding_id": "GOV-POL-001",
   "failure": "Policies exist without verified implementation",
   "impact": "Documented intent does not reduce technical risk",
   "accountable_owner": "CISO",
   "recommendation": "Require evidence-backed control attestations"
  },
  {
   "category": "Metrics and Accountability",
   "finding_id": "GOV-MET-001",
   "failure": "Metrics are not tied to remediation decisions",
   "impact": "Overdue high-risk work may not be escalated",
   "accountable_owner": "Executive Risk Committee",
```


Figure 6: Governance failure analysis. Technical observations are translated into ownership, impact, and remediation decisions.

Part 3 — Implementing Security Governance Controls

The secure configuration replaces the vulnerable training service, removes default credentials, keeps the database off host ports, and separates frontend and internal data networks. Monitoring captures dated service evidence, while the oversight register assigns owners, review dates, thresholds, and escalation routes. Verification uses direct container and HTTP checks rather than relying solely on implementation status.

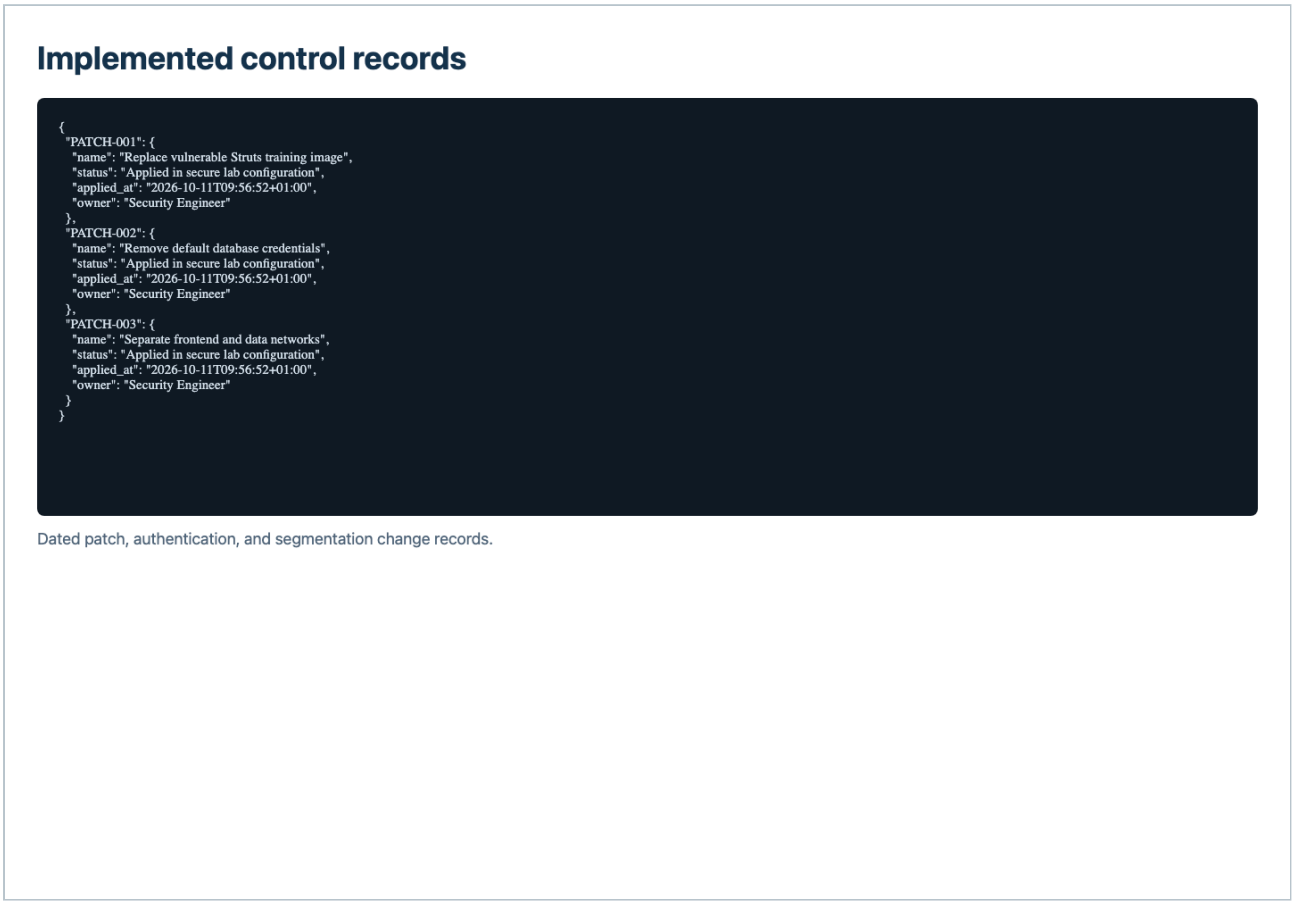
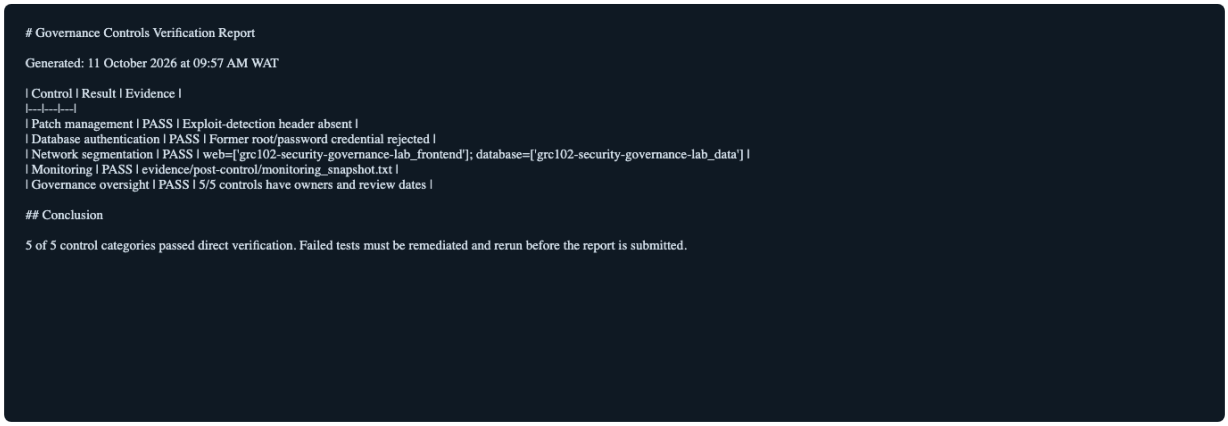


Figure 7: Implemented control records. Dated records document the controlled replacement, database hardening, and segmentation changes.

Control verification



```
# Governance Controls Verification Report

Generated: 11 October 2026 at 09:57 AM WAT

| Control | Result | Evidence |
|---|---|---|
| Patch management | PASS | Exploit-detection header absent |
| Database authentication | PASS | Former root/password credential rejected |
| Network segmentation | PASS | web=['grc102-security-governance-lab_frontend']; database=['grc102-security-governance-lab_data'] |
| Monitoring | PASS | evidence/post-control/monitoring_snapshot.txt |
| Governance oversight | PASS | 5/5 controls have owners and review dates |

## Conclusion

5 of 5 control categories passed direct verification. Failed tests must be remediated and rerun before the report is submitted.
```

Direct verification results from the secure Docker configuration.

Figure 8: Post-control verification. Independent checks test patch behaviour, credentials, networks, monitoring, and oversight.

Post-control vulnerability scan


```
{
 "scan_date": "2026-10-11T09:57:13+01:00",
 "mode": "post-control",
 "authorised_scope": "Local Docker lab only",
 "findings": [
  {
   "id": "CVE-2017-5638",
   "title": "Apache Struts S2-045",
   "severity": "None",
   "vulnerable": false,
   "evidence": "Exploit-detection header absent"
  },
  {
   "id": "DB-AUTH-001",
   "title": "Default database credentials",
   "severity": "None",
   "vulnerable": false,
   "evidence": "Default root/password authentication rejected"
  },
  {
   "id": "NET-SEG-001",
   "title": "Insufficient network segmentation",
   "severity": "None",
   "vulnerable": false,
   "evidence": "No shared Docker network between web and database"
  }
 ],
 "summary": {
  "critical": 0,
  "high": 0,
  "medium": 0,
  "low": 0,
  "unknown": 0
 }
}
```


The same scanner rerun against the controlled environment.

Figure 9: Post-control scan. The baseline scanner is repeated to make the before-and-after comparison consistent.

Part 4 — Developing Security Governance Metrics and Reporting

The dashboard derives its current state from the saved scan and control-verification evidence. Its metrics cover patching, remediation time, unresolved high-risk findings, monitoring, test results, and ownership. Targets make exceptions visible and connect operational evidence to decisions required from management and the board.

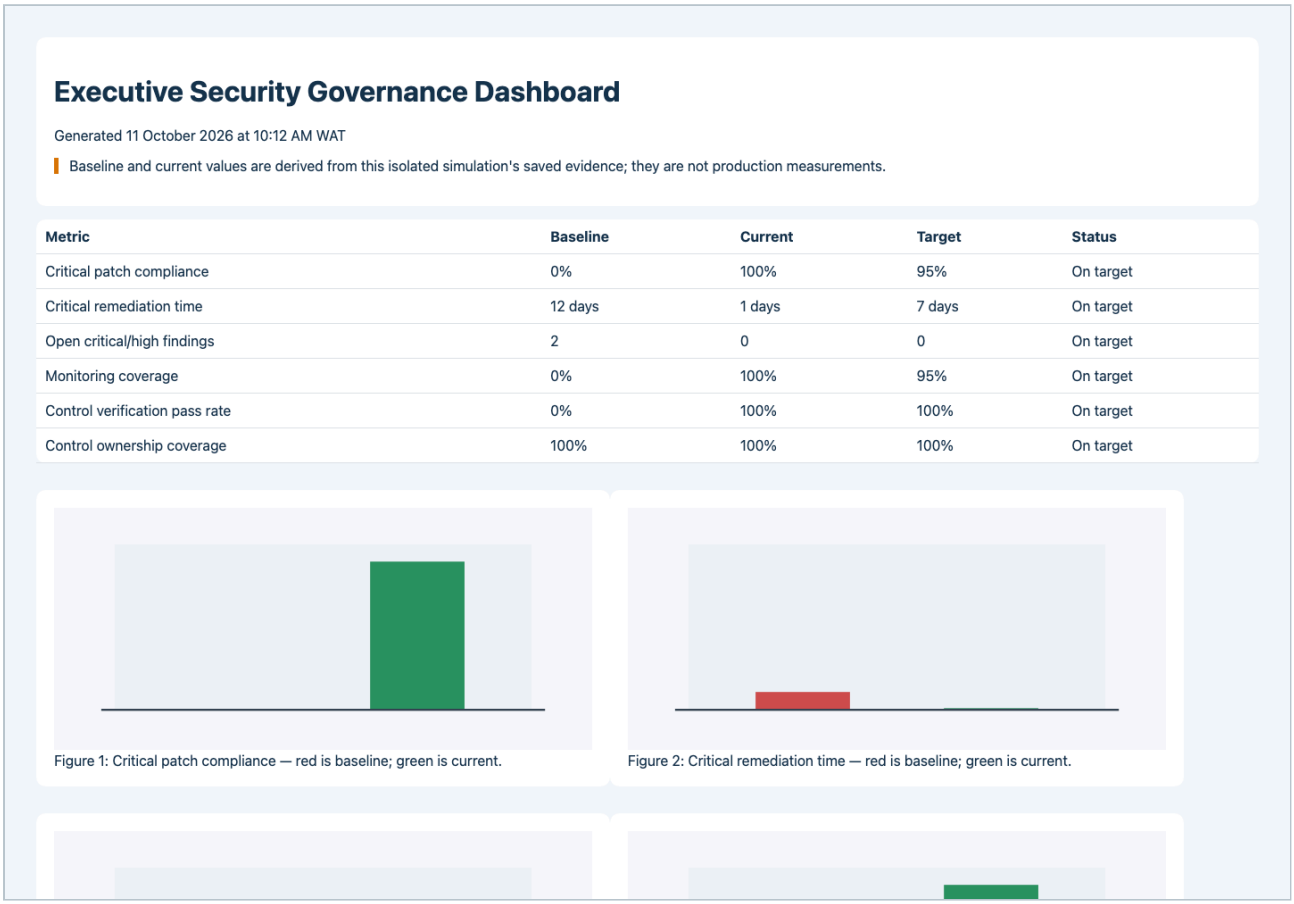


Figure 10: Executive dashboard. Evidence-derived metrics present targets, current state, residual risk, and management action.

Governance value

Evidence-backed reporting helps leadership distinguish implemented controls from stated intent. Named owners and escalation thresholds make overdue risk actionable, while repeatable before-and-after tests support auditability and continuous oversight.

References

- U.S. GAO, *Data Protection: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach*, GAO-18-559 (2018).
- U.S. House Committee on Oversight and Government Reform, *The Equifax Data Breach* (2018).

- NIST National Vulnerability Database, CVE-2017-5638.
- ICDFA, GRC102 Week 8 Lab Instructions.